

ACTIVITY PACK

Activity 1: Security Checklist

Activity 1 - Threat Modelling a Generative AI Concierge

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	2.1 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Security Checklist

Activity 1 - GenAI Concierge Security Checklist

Use this checklist to turn the threat model into a deployment decision. Mark each item Yes, No, or Not evidenced, and cite the scenario artefact that supports your answer.

Purpose and ownership

- ☐ The concierge has a named business owner, technical owner, security reviewer and DPO contact.
- ☐ Permitted guest tasks, prohibited tasks and supported channels are documented.
- ☐ Expansion to other properties requires a fresh risk and cross-border data review.

Content and data

- ☐ Every input source is classified by owner, trust level, update method and data sensitivity.
- ☐ Guest profiles, prompts, retrieved content, outputs, tool arguments and logs appear in the personal-data inventory.
- ☐ Retrieval is scoped to the current authenticated guest and stay; public users cannot reach guest data.
- ☐ Retention and deletion periods exist for conversations, memory, screenshots and logs.

Tools and actions

- ☐ The agent has a distinct identity and separate read/write permissions for each tool.
- ☐ Tool parameters bind room, guest and reservation identifiers before execution.
- ☐ Folio email goes only to a verified registered address; recipient override is impossible.
- ☐ Charges, refunds, profile changes and cross-guest disclosures require deterministic human approval.
- ☐ Rate, cost, retry and sequence limits prevent runaway actions.

Detection and response

- ☐ Logs distinguish user input, retrieved content, model proposal, approval and executed action.
- ☐ Alerts cover cross-guest retrieval, unoccupied-room orders, recipient changes and unusual tool sequences.
- ☐ A kill switch, credential-revocation path, owner and response time are tested.
- ☐ The DPO can assess significant harm and scale using preserved evidence.

Decision

- ☐ Proceed.
- ☐ Proceed only after the stated controls are evidenced.
- ☐ Halt because the use case cannot be bounded within risk tolerance.

Record the three highest-priority gaps, the owner for each remediation and the due date.